

Festo Smart Factory Lab - Final Assignment

Aleksander Kłap - Lourdes Gaurisse

June 22, 2026

Contents

1	Inventory	1
1.1	Infrastructure / Level 0 Network	1
1.2	Station 0 – Robot Arm (172.21.0.x)	1
1.3	Station 1 – Conveyor Belt (172.21.1.x)	1
1.4	Station 2 – Ball Sorting / Dispense (172.21.2.x)	2
1.5	Station 3 – Camera Inspection (172.21.3.x)	2
1.6	PLC Segment – Stations 2 & 3	2
1.7	Station 4 – Magazine (172.21.4.x)	3
1.8	Station 5 – Muscle Press (172.21.5.x)	3
1.9	Station 6 – Oven (172.21.6.x)	3
2	Trust Zones and Segmentation	5
2.1	Regulatory and Standards Alignment	5
2.2	Network Identification	7
2.3	Security Weaknesses	8
2.4	Standards Alignment Summary	15
3	Threat Modelling	16
3.1	Attacker Profiles	16
3.2	Threat Scenarios	16
3.3	Threat Table	17
4	Risk Matrix	18
5	Security Requirements	19
6	Logical Network Redesign	23
6.1	Logic Zones	24
6.2	New Nodes	24
6.3	Firewalls	25
6.4	Network Implementation	25
6.5	VLAN Segmentation & Restricted Routing	26
6.6	Justified Protocols Routes	27
7	Protocol Hardening	28
7.1	Profinet	28
7.2	OPC UA	28
7.3	MQTT	28
7.4	HTTP/Web Interfaces	28
7.5	S7comm+ Engineering Access	29
8	Security Hardware	30
8.1	Industrial Firewall	30
8.2	Managed Switch	30

8.3	Engineering Station	30
8.4	IDMZ proxy server	30
8.5	Syslog & Backup Storage	31
9	Organizational & Procedural Measures	32
9.1	User Roles	32
9.2	Backup Strategy	32
9.3	Incident Response	32

List of Tables

1	Assessment Scope Key Findings	5
2	IEC 62443 Violations	5
3	ISO/IEC 27001 Violations	6
4	NIS2 Directive Violations	6
5	Defense-in-Depth Violations	6
6	Least Privilege & Zero Trust Violations	7
7	OT Network Devices	7
8	IT / MES Network Devices	7
9	Security Weaknesses Summary	9
10	Flat network architecture allowing unrestricted communication	9
11	Unrestricted access to PLC services from any host on the OT subnet	10
12	Direct communication paths between MES and OT systems without network separation	10
13	Undocumented device maintaining persistent programming access to PLC S2	11
14	PLC web services exposed over unauthenticated plaintext HTTP	11
15	Network-wide accessibility of OPC-UA services without verified security controls	12
16	TP-Link access point present on the operational technology network	12
17	Visitor laptop connected directly to the live OT environment	13
18	VMware host operating on the OT subnet with undocumented virtual machines	13
19	Medium and Low Severity Findings	14
20	Standards Compliance Summary	15
21	ICS Threat Analysis Matrix (IEC 62443-based)	17
22	ICS Threat Risk Assessment	18

List of Figures

1	Zone & Conduit Diagram	23
2	Network Implementation	26

1 Inventory

1.1 Infrastructure / Level 0 Network

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
Gateway	Router / Firewall	?	172.21.0.230	?	Ethernet	Network gateway for all stations
festo-mes-pc	MES PC	SIMATIC-PC	172.21.0.90	4c:d7:17:90:73:a2	PROFINET / Ethernet	MES / NTP Server
desktop-6jd9li	Engineering PC	SIMATIC-PC	172.21.0.168 / 172.21.0.192	02:1b:1b:29:49:00 / 08:26:ae:3ea5:ad	Ethernet	Dual-NIC engineering/admin station
gebruik-tt8ke80	Physical NIC	SIMATIC-PC	172.21.0.165	60:cf:84:d1:d0:d5	Ethernet	VMWare Virtualisation Host
gebruik-tt8ke80	VMWare Virtual NIC	VMWare	172.21.0.165	00:0c:29:63:ba:59	?	VMWare Virtual NIC
CPX-IOT	MQTT Broker?	Festo	172.21.0.210	00:0E:F0:7C:A3:C0	?	?
Engineering Workstation	Engineering PC	?	172.21.0.156	c4:c6:e6:d4:c3:81	S7comm, SSDP M-SEARCH	Engineering station connecting to PLC S2 (TIA Portal?)
Smart Switch	Switch	Netgear GS305E / V1.0.0.16	172.21.0.196	28:94:01:67:5b:8b	?	?
Router or AP	Router	TP-Link router	172.21.0.200	20:23:51:41:a2:88	UDP	Router?

1.2 Station 0 – Robot Arm (172.21.0.x)

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
Robot Arm	Robot	Universal Robots UR3e / ?	172.21.1.40	?	UR Bus / Ethernet	Pick & place cobot
Switch S0	Switch	Siemens Scalance XB008	N/A (unmanaged)	N/A (unmanaged)	Ethernet	Station 0 network distribution
rfidboxcobot	RFID Reader	Turck TBEN-S2-2RFID-4DXP	172.21.1.20	00:07:46:aa:07:cc	PROFINET	RFID identification near cobot

Switch S0 – Port Connections

Port	Connected To
P1	Connector pinout
P2	—
P3	—
P4	Station 2 HMI
P5	UR extension bus
P6	—
P7	—
P8	—

1.3 Station 1 – Conveyor Belt (172.21.1.x)

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
Switch S1	Switch	Siemens Scalance XB008	N/A (unmanaged)	N/A (unmanaged)	Ethernet	Station 1 network distribution
HMI S1?	HMI	Siemens MTP700 Unified Comfort	172.21.1.10	30:13:89:35:da:a8	PROFINET	Operator panel — confirm station ownership
PLC S1	PLC	Siemens CPU 1512SP F-1 PN (S7-1500, ET 200SP) / V3.0.3	172.21.1.1	30:B8:51:32:D3:E7	PROFINET, HTTP, OPC-UA, S7comm	Process control S1
PC Cobot-ML	PC	?	172.21.1.90	08:bf:b8:f1:25:e3	OPC-UA	?

Switch S1 – Port Connections

Port	Connected To
P1	—
P2	Switch S2
P3	Station 2 HMI
P4	—
P5	—
P6	—
P7	—
P8	—

1.4 Station 2 – Ball Sorting / Dispense (172.21.2.x)

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
PLC S2	PLC	Siemens CPU 1512SP F-1 PN (S7-1500, ET 200SP) / V3.0.3	172.21.2.1	30:b8:51:33:7e:c7	PROFINET, HTTP, OPC-UA, S7comm	Process control S2
HMI S2	HMI	Siemens MTP700 Unified Comfort	172.21.2.10	30:13:89:35:d8:a1	PROFINET	Operator panel (hmi2dispense)
Switch S2	Switch	Siemens Scalance XB008	N/A (unmanaged)	N/A (unmanaged)	Ethernet	Station 2 network distribution
CPX Programmable Controller S2	Controller	Siemens	172.21.2.60	00:0E:F0:99:CB:38	?	Controller for industrial automation
Power Monitor S2	Monitor	Siemens	172.21.2.61	10:DF:FC:17:DC:72	?	Power consumption monitoring
IO Device	IO Device	Siemens ET200SP IM155-6PN/2 HF, 6ES7 155-6AU01-0CN0 / V4.2.4, HW: V4.0.0	172.21.2.100	Port A: 4c:e7:05:4b:46:4b, Port B: 4c:e7:05:4b:46:4c	PROFINET IO	Remote IO Module

Switch S2 – Port Connections

Port	Connected To
P1	Switch S1
P2	Switch S3
P3	PLC front (→ SCALANCE XB008)
P4	IO Device
P5	—
P6	Power Monitor
P7	Switch S0
P8	PC Cobot-ML (172.21.1.90)

1.5 Station 3 – Camera Inspection (172.21.3.x)

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
PLC S3	PLC	Siemens CPU 1512SP F-1 PN (S7-1500, ET 200SP) / V3.0.3	172.21.3.1	30:b8:51:32:d3:9b	PROFINET, HTTP, OPC-UA, S7comm	Process control S3 (plcxbfesto62c9)
HMI S3	HMI	Siemens MTP700 Unified Comfort	172.21.3.10	30:13:89:2c:e9:c5	PROFINET	Operator panel
Switch S3	Switch	Siemens Scalance XB008	N/A (unmanaged)	N/A (unmanaged)	Ethernet	Station 3 network distribution
Sensor S3	Sensor	SensoPart / ?	172.21.3.50	00:19:6F:0D:A3:72	HTTP	Vision / inspection sensor
Power Monitor S3	Monitor	?	?	?	?	Power consumption monitoring

Switch S3 – Port Connections

Port	Connected To
P1	Switch S2
P2	Switch S4
P3	PLC front (→ SCALANCE XB008)
P4	Sensor
P5	Upward / general switch (confirm)
P6	Power Monitor
P7	Switch S0
P8	PC Cobot-ML / upward? (confirm)

1.6 PLC Segment – Stations 2 & 3

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
SCALANCE XB008	Switch	Siemens SCALANCE XB008	N/A (unmanaged)	N/A (unmanaged)	PROFINET	PLC-side managed switch
PC Cobot-ML	Industrial PC	?	172.21.1.90	08:bf:b8:fl:25:e3	Ethernet	ML inference / cobot control

PLC Connections

Interface	Connected To
X1P3 (PROFINET LAN)	SCALANCE XB008
HMI port	pnl-L-HMI-T7-V2

1.7 Station 4 – Magazine (172.21.4.x)

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
PLC S4	PLC	Siemens CPU 1512SP F-1 PN (S7-1500, ET 200SP) / V3.0.3	172.21.4.1	30:b8:51:33:7e:24	PROFINET, HTTP, OPC-UA, S7comm	Process control S4 (plcmagback)
HMI S4	HMI	Siemens MTP700 Unified Comfort	172.21.4.10	30:13:89:35:D9:EF	PROFINET	Operator Panel
Switch S4	Switch	Siemens Scalance XB008	N/A (unmanaged)	N/A (unmanaged)	Ethernet	Station 4 network distribution
CPX Terminal	Cloud I/O Device	Festo CPX (197330)	?	?	?	Cloud-connected valve/IO terminal

Switch S4 – Port Connections

Port	Connected To
P1	Station 3 HMI
P2	PLC S4
P3	Switch S5
P4	—
P5	CPX Terminal
P6	—
P7	—
P8	—

1.8 Station 5 – Muscle Press (172.21.5.x)

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
PLC S5	PLC	Siemens CPU 1512SP F-1 PN (S7-1500, ET 200SP) / V3.0.3	172.21.5.1	30:b8:51:33:7e:62	PROFINET, HTTP, OPC-UA, S7comm	Process control S5 (plcxamikea2a4)
HMI S5	HMI	Siemens MTP700 Unified Comfort	172.21.5.10	30:13:89:36:6A:EE	PROFINET	Operator Panel
Switch S5	Switch	Siemens Scalance XB008	N/A (unmanaged)	N/A (unmanaged)	Ethernet	Station 5 network distribution

Switch S5 – Port Connections

Port	Connected To
P1	Switch S4
P2	Switch S6
P3	PLC S5
P4	—
P5	—
P6	—
P7	—
P8	—

1.9 Station 6 – Oven (172.21.6.x)

Asset	Type	Model / Firmware	IP	MAC	Available Protocols	Function
HMI S6	HMI	Siemens MTP700 Unified Comfort	172.21.6.10	30:13:89:35:d9:c7	PROFINET	Operator panel
Switch S6	Switch	Siemens Scalance XB008	N/A (unmanaged)	N/A (unmanaged)	Ethernet	Station 6 network distribution
PLC S6	PLC	Siemens CPU 1512SP F-1 PN (S7-1500, ET 200SP) / V3.0.3	172.21.6.1	30:B8:51:32:D4:5F	PROFINET, HTTP, OPC-UA, S7comm	Process control S6
Power Monitor S6	Monitor	?	172.21.6.61	10:DF:FC:17:DC:6C	?	Power consumption monitoring
CPX Programmable Controller S6	Controller	Festo	172.21.6.60	00:0E:F0:93:AF:99	PROFINET	?

Switch S6 – Port Connections

Port	Connected To
P1	Switch S5
P2	Power Monitor
P3	PLC S6
P4	—
P5	—
P6	—
P7	—
P8	—

2 Trust Zones and Segmentation

This assessment evaluates the security posture of the Festo Smart Factory Lab OT/ICS network. The lab comprises six manufacturing stations (conveyor, sorting, camera inspection, magazine, press, oven) plus a robot arm cell, interconnected through Siemens S7-1500 PLCs, Festo CPX controllers, MTP700 HMIs, and a centralised MES PC.

The assessment is based on passive packet capture analysis (5 captures, 55,000 frames), active DCP Identify-All output (14 devices), and nmap host discovery (21 live hosts across 172.21.0.0/18).

Assessment Scope	Key Finding
Network segmentation	NONE — fully flat /18 subnet
PLC access control	NONE — all PLCs reachable from any host
MES / OT separation	NONE — MES PC shares subnet with PLCs
Engineering access control	NONE — uncontrolled, incl. unregistered devices
Unaccounted assets	6+ devices not in original inventory
Wireless / external exposure	TP-Link AP present on OT subnet

Table 1: Assessment Scope Key Findings

The overall security posture is assessed as **CRITICAL**. The network presents no meaningful barrier between IT systems, engineering workstations, visitor devices, and live industrial control equipment. A single compromised host on the subnet has unrestricted access to all PLCs and HMIs.

2.1 Regulatory and Standards Alignment

IEC 62443 Violations

Security Issue Found	Standard Violated
No zones or conduits — entire network is one implicit zone with no conduit controls	IEC 62443-1-1 (Zone & Conduit Model)
Incomplete asset inventory (6+ undocumented devices during active operation)	IEC 62443-2-1 (CSMS — Asset Inventory)
No authentication on PLC web servers or PROFINET	IEC 62443-3-3 / SR 1.1 (Human User Identification & Authentication)
No controlled access path for remote engineering	IEC 62443-3-3 / SR 2.6 (Remote Session Termination)
No network segmentation or zone boundary protection	IEC 62443-3-3 / SR 5.1 & SR 5.2 (Network Segmentation & Zone Boundary Protection)

Table 2: IEC 62443 Violations

ISO/IEC 27001 Violations

Security Issue Found	Standard Violated
Six devices absent from inventory, including one actively programming PLCs via S7comm (172.21.0.156)	Clause 8.1 / Annex A.8 (Asset Management)
Flat /18 subnet with no separation between services, users, or systems	Annex A.8.22 (Network Segmentation)
No firewall, ACL, or VLAN between MES-level and field-level devices	Annex A.8.20 (Network Security)

Table 3: ISO/IEC 27001 Violations

NIS2 Directive Violations

Security Issue Found	Standard Violated
No network segmentation, access control, or asset management in lab network	Article 21 — Cybersecurity Risk Management
Devices from multiple vendors (Siemens, Festo, Turck, SensoPart, TP-Link) with unknown/unverified firmware	Article 21(2)(e) — Supply Chain Security
Visitor/external laptop (Kyan_laptop, a0:ce:c8:f7:ab:c9) on live OT subnet — no network admission controls	Article 21(2)(h) — Basic Cyber Hygiene & Training

Table 4: NIS2 Directive Violations

Defense-in-Depth Violations

Security Issue Found	Standard Violated
Only one perimeter exists (edge of /18 subnet) — no segmentation between IT and OT	Defense-in-Depth — Multiple Independent Controls
No DMZ or IDMZ between MES and field layers	Defense-in-Depth — Layered Architecture
No per-PLC firewall or ACL	Defense-in-Depth — Compartmentalization
No authentication on PROFINET, S7comm, or PLC web servers	Defense-in-Depth — Authentication Layer
Single perimeter breach allows unrestricted lateral movement to all PLCs	Defense-in-Depth — No Fallback Controls

Table 5: Defense-in-Depth Violations

Least Privilege & Zero Trust Violations

Security Issue Found	Standard Violated
MES PC (172.21.0.90) can reach every other PLC, not just the one it needs (PLC S2)	Least Privilege — Only Necessary Access
MES PC is reachable from PLCs via NTP and can poll HMIs unnecessarily	Least Privilege — Unrestricted Bidirectional Access
Engineering PCs have persistent S7comm access instead of only during programming windows	Least Privilege — Continuous Unnecessary Access
PC Cobot-ML (172.21.1.90) can reach PLCs S1, S3–S6 despite needing only OPC-UA to PLC S2	Least Privilege — Default Deny / Explicit Allow
Every device trusts every other device based on subnet membership, not verified identity or role	Zero Trust — No Implicit Trust Based on Network Location

Table 6: Least Privilege & Zero Trust Violations

2.2 Network Identification

Observed Topology

The entire lab operates on a single flat subnet: **172.21.0.0/18** (broadcast 172.21.63.255, gateway 172.21.0.230). No VLANs, no firewall zones, and no routing boundaries were observed between any device classes. All hosts - from the MES PC to individual PLCs and HMIs - share the same Layer 2 broadcast domain.

OT Network

Device	IP	Type	Notes
PLC S1–S6	172.21.x.1	Siemens S7-1500 PLCs	Process controllers, each exposing HTTP/80, OPC-UA/4840, S7comm/102, PROFINET
HMI S1–S6	172.21.x.10	Siemens MTP700	Operator panels, PROFINET
Robot Arm	172.21.1.40	Universal Robots UR3e	Cobot, firmware unconfirmed
rfidboxcobot	172.21.1.20	Turck TBEN-S2-2RFID	RFID reader, PROFINET
Sensor S3	172.21.3.50	SensoPart	Vision sensor, HTTP
ET200SP IO S2	172.21.2.100	Siemens IM155-6PN/2 HF	PROFINET IO device, FW V4.2.4
CPX Controller S2	172.21.2.60	Festo CPX	Protocol unconfirmed
CPX Controller S6	172.21.6.60	Festo CPX	PROFINET RT cyclic confirmed (UDP 1740–1743)
Power Monitor S2	172.21.2.61	Siemens (10:DF:FC OUI)	Protocol unconfirmed
Power Monitor S6	172.21.6.61	Siemens (10:DF:FC OUI)	Protocol unconfirmed

Table 7: OT Network Devices

IT / MES Network

Device	IP	Role	Notes
festo-mes-pc	172.21.0.90	MES / NTP Server	Polls PLC S2 alarm table every ~3 s; NTP master; OPC-UA client to PLC S2
desktop-6jd9ili	172.21.0.168 / .192	Engineering PC (dual-NIC)	SIMATIC-PC family; TIA Portal host presumed
gebruik-tt8ke80	172.21.0.165	VMware Host	Two MACs: physical NIC (60:cf:84) + VMware vNIC (00:0c:29); VM roles unknown
PC Cobot-ML	172.21.1.90	ML Inference PC	OPC-UA client to PLC S2
CPX-IOT	172.21.0.210	Unknown / MQTT?	Festo device; silent during all captures — cloud link unconfirmed

Table 8: IT / MES Network Devices

Engineering Access

At least three distinct engineering/programming channels were observed or inferred, none of which pass through any controlled access path:

- **desktop-6jd9ili** (172.21.0.168 / 172.21.0.192): Registered engineering PC with dual NICs. Presumed TIA Portal host.
- **172.21.0.156** (MAC c4:c6:e6:d4:c3:81): Unregistered device. Maintained a persistent S7comm/102 session to PLC S2 across all five captures. Consistent with TIA Portal or Step 7 in online monitoring mode. This device is not in any inventory version.
- **Kyan_laptop** (172.21.0.179, MAC a0:ce:c8:f7:ab:c9): Identified by DCP as SIMATIC-PC family. Likely a student or visitor machine admitted to the OT subnet without restriction.

External & Cloud Connections

Two devices raise concerns about external connectivity:

- **TP-Link device** (172.21.0.200): Identified via UPnP SSDP as a TP-Link access point or router (MiniUPnPd/1.8). Broadcasts on TP-Link proprietary discovery port UDP/20002. If this device has a WAN port or wireless interface bridged to the OT subnet, it represents a direct internet-facing exposure.
- **CPX-IOT** (172.21.0.210): Festo device, OUI 00:0E:F0. Produced zero traffic in all five captures. The name ‘IOT’ and the CPX product line’s known cloud connectivity features suggest it may be a cloud gateway (MQTT over internet). Its silence during captures could indicate an idle state or encrypted tunnelled traffic not visible at Layer 2.

Flat vs. Segmented Assessment

The network is entirely flat. There is no evidence of any segmentation mechanism:

- No VLANs (capture1 shows VLAN tag value 0 = untagged/priority-tagged only on the PROFINET cyclic traffic, not a segmentation VLAN)
- No routed boundaries between device classes
- No firewall between MES and PLCs
- No DMZ or IDMZ between IT and OT layers
- No 802.1X or MAC-based port security on any observed switch

From a Purdue Model / IEC 62443 zone perspective: the network presents as a single undifferentiated zone spanning Levels 0 through 3, with potential Level 4 exposure via the TP-Link device and CPX-IOT.

2.3 Security Weaknesses

Findings are rated CRITICAL / HIGH / MEDIUM / LOW based on exploitability and potential impact on process availability, safety, and data integrity.

ID	Severity	Finding
F-01	CRITICAL	Fully flat /18 network - no zone or conduit separation
F-02	CRITICAL	PLCs directly reachable from all hosts - no access control
F-03	CRITICAL	MES PC has unrestricted protocol access to all OT devices
F-04	CRITICAL	Unregistered device actively programming PLCs via S7comm
F-05	HIGH	PLC web servers expose HTTP (plaintext) on the OT subnet
F-06	HIGH	OPC-UA servers on PLCs accessible network-wide with no observed auth
F-07	HIGH	TP-Link AP present on OT subnet - potential wireless attack surface
F-08	HIGH	Visitor/unvetted laptop (Kyan_laptop) on live OT network
F-09	HIGH	gebruik-tt8ke80 runs VMware with unknown VM roles on OT subnet
F-10	MEDIUM	CPX-IOT cloud gateway: function and traffic unconfirmed
F-11	MEDIUM	PROFINET carries no authentication - DCP allows rename/reconfigure
F-12	MEDIUM	Power monitor and CPX controller protocols unconfirmed
F-13	MEDIUM	Robot arm firmware version unverified
F-14	LOW	NTP synchronisation provided by MES PC - single point of failure

Table 9: Security Weaknesses Summary

F-01 - CRITICAL: Fully Flat /18 Network

Standard Ref	IEC 62443-1-1 (Zone & Conduit model) · IEC 62443-3-3 SR 5.1, SR 5.2 · ISO/IEC 27001 A.8.22 · NIS2 Art. 21
Observation	All 21+ live hosts share 172.21.0.0/18 with no VLAN, no routed boundary, and no firewall between device classes. PLCs (Level 1/2), HMIs (Level 2), MES (Level 3), engineering PCs, visitor laptops, and infrastructure devices are on one broadcast domain.
Impact	Any compromised or malicious host has Layer 3 reachability to every PLC, HMI, and sensor. Lateral movement from an infected engineering laptop to all six PLCs requires no exploitation of additional controls - there are none.
Recommendation	Implement a Purdue Model segmentation: Level 0/1 (field), Level 2 (control/HMI), Level 3 (MES), separated by firewalls or managed switch ACLs with an IDMZ between Levels 2 and 3. Each station subnet (172.21.x.0/24) should be a discrete security zone.

Table 10: Flat network architecture allowing unrestricted communication

F-02 - CRITICAL: Unrestricted PLC Access

Standard Ref	IEC 62443-3-3 SR 1.1, SR 1.2, SR 5.1 · Defense-in-Depth · Least Privilege
Observation	All S7-1500 PLCs expose HTTP/80 (web server), OPC-UA/4840, and S7comm/102 simultaneously to the entire subnet. Confirmed by TCP conversation analysis across all captures. No authentication was observed at the network layer for any of these services.
Impact	An attacker on any host in the /18 can connect to any PLC's S7comm port, issue read/write requests to process data, download or upload program blocks, or force a CPU STOP - without needing any credentials. All six production stations are simultaneously vulnerable from a single entry point.
Recommendation	Apply PLC-level access controls: (1) Disable unused services (HTTP web server if not required for operations). (2) Enable TIA Portal's 'Know-How Protection' and CPU access protection. (3) Restrict S7comm/102 and OPC-UA/4840 to specific source IPs via firewall ACL. Engineering S7comm access should only be permitted from the engineering VLAN during active maintenance windows.

Table 11: Unrestricted access to PLC services from any host on the OT subnet

F-03 - CRITICAL: No MES / OT Separation

Standard Ref	IEC 62443-2-1 (CSMS) · IEC 62443-3-3 SR 5.2 · ISO/IEC 27001 A.8.22 · Purdue Model Level 3 / Level 2 boundary
Observation	festo-mes-pc (172.21.0.90) communicates directly with PLC S2 via HTTP (alarm polling), OPC-UA (process data), and NTP - all unmediated, with no DMZ or proxy. The MES and HMI S2 also exchange NTP directly.
Impact	The MES PC is a Windows-based SIMATIC-PC system and the most likely target for phishing, software supply-chain, or remote-access attacks. Compromise of the MES PC gives an attacker an already-trusted, persistent connection to PLC S2's control interface. Conversely, a malformed PLC response could exploit vulnerabilities in the MES software.
Recommendation	Introduce an IDMZ (Industrial DMZ) between the MES and the OT layer. Only specific, validated protocols should traverse the IDMZ in defined directions: historian replication should be unidirectional (OT→IT only, via a data diode or enforced one-way gateway). Alarm polling from MES to PLC should be proxied through an application-layer gateway rather than a direct TCP session.

Table 12: Direct communication paths between MES and OT systems without network separation

F-04 - CRITICAL: Unregistered Device Programming PLCs

Standard Ref	IEC 62443-2-1 (Asset Management / Change Control) · ISO/IEC 27001 A.8.1, A.8.19 · Zero Trust
Observation	IP 172.21.0.156 (MAC c4:c6:e6:d4:c3:81, OUI unresolved) maintained a persistent, high-volume S7comm session to PLC S2 across all five capture files. This device appears in no version of the asset inventory. Its behaviour is consistent with TIA Portal in online monitoring or active programming mode.
Impact	An unidentified device with S7comm write access to a live PLC represents a rogue programmer scenario. If this device is compromised or malicious, it can alter PLC logic, inject faults, or cause unsafe states on Station 2 without any audit trail. Its absence from the inventory means no baseline behaviour exists against which to detect anomalies.
Recommendation	Immediately identify this device physically. Cross-reference the MAC with switch port tables. If it is a legitimate engineering station, add it to the inventory and bring it under change control. If it cannot be accounted for, treat as an incident. Engineering access to PLCs should require 802.1X authentication and be logged; S7comm should be blocked at the network layer outside authorised programming windows.

Table 13: Undocumented device maintaining persistent programming access to PLC S2

F-05 - HIGH: PLC HTTP Web Servers (Plaintext)

Standard Ref	IEC 62443-3-3 SR 1.3 (Authenticator Management) · Defense-in-Depth
Observation	PLC S2 serves HTTP on port 80. The MES PC issues unauthenticated GET requests to /ClientArea/AlarmTable.mwsl approximately every 3 seconds. No TLS/HTTPS was observed. The same HTTP web server capability is present on all S7-1500 PLCs.
Impact	Alarm and diagnostic data is transmitted in plaintext and can be intercepted or spoofed by any host on the subnet. The web server also provides a browser-accessible interface to PLC diagnostics that any subnet host can reach without authentication.
Recommendation	If the PLC web server is used operationally: (1) Enable HTTPS in TIA Portal PLC properties. (2) Enable access control / user authentication on the web server. (3) Restrict HTTP/HTTPS access to the MES PC IP only via firewall ACL. If the web server is not required, disable it entirely in TIA Portal.

Table 14: PLC web services exposed over unauthenticated plaintext HTTP

F-06 - HIGH: OPC-UA Accessible Network-Wide

Standard Ref	IEC 62443-3-3 SR 1.1 · Least Privilege · Zero Trust
Observation	OPC-UA port 4840 on PLC S2 receives connections from both 172.21.0.90 (MES PC) and 172.21.1.90 (PC Cobot-ML). No certificate-based authentication or SecurityPolicy enforcement was verifiable from packet analysis. OPC-UA is likely running in ‘None’ security mode, which is the S7-1500 default without explicit TIA Portal configuration.
Impact	Any host on the /18 subnet can connect to the OPC-UA server and read/write process variables, depending on the server’s address space configuration. OPC-UA with no security mode provides no protection against eavesdropping, tampering, or replay attacks.
Recommendation	Configure OPC-UA to use SecurityMode=SignAndEncrypt with Basic256Sha256 or better. Deploy client certificates and enforce server-side certificate validation. Firewall OPC-UA/4840 to authorised client IPs only.

Table 15: Network-wide accessibility of OPC-UA services without verified security controls

F-07 - HIGH: TP-Link Access Point on OT Subnet

Standard Ref	NIS2 Art. 21 · IEC 62443-2-1 · Defense-in-Depth
Observation	172.21.0.200 (MAC 20:23:51:41:a2:88) was identified via UPnP SSDP as a TP-Link device running MiniUPnPd. It broadcasts on UDP/20002 (TP-Link proprietary management). If this device has a wireless interface bridged or NATted to the OT subnet, the physical perimeter of the lab network is effectively removed.
Impact	A wireless interface on the OT subnet enables attacks from outside the lab without physical access. Even if the wireless is WPA2-protected, consumer-grade TP-Link firmware has a poor security patching record and a history of CVEs. Critically, MiniUPnPd is an internet-facing port-forwarding daemon - it may be exposing OT services externally.
Recommendation	Remove the TP-Link device from the OT subnet immediately or isolate it on a separate management VLAN with no OT reachability. Audit the device’s WAN/port-forwarding configuration. If internet access is required in the lab for administrative purposes, it must traverse a firewall on a separate IT network segment.

Table 16: TP-Link access point present on the operational technology network

F-08 - HIGH: Visitor/Unvetted Laptop on OT Network

Standard Ref	NIS2 Art. 21(2)(h) · IEC 62443-2-1 (Access Management) · Zero Trust
Observation	Kyan_laptop (172.21.0.179, MAC a0:ce:c8:f7:ab:c9) was identified by DCP scan as a SIMATIC-PC family device - indicating it has PROFINET network drivers installed, consistent with a student or lab visitor who has configured their laptop for PROFINET work. It was admitted to the live OT subnet without apparent restriction.
Impact	A personal or student laptop is far more likely to carry malware, have unpatched software, or be used outside the lab on untrusted networks than a managed workstation. Once on the OT subnet, it has the same access to PLCs as any other device.
Recommendation	Implement network admission control (802.1X or MAC allowlisting on the lab switches). Visitor/student devices should only access a dedicated quarantine VLAN with no OT reachability. If PROFINET access is needed for lab exercises, use a dedicated lab PC, not personal devices.

Table 17: Visitor laptop connected directly to the live OT environment

F-09 - HIGH: VMware Host with Unknown VM Roles

Standard Ref	ISO/IEC 27001 A.8.1 (Asset Management) · IEC 62443-2-1 · Defense-in-Depth
Observation	gebruik-tt8ke80 (172.21.0.165) presents two MACs at the same IP: 60:cf:84:d1:d0:d5 (physical NIC) and 00:0c:29:63:ba:59 (VMware virtual NIC, OUI confirmed). The roles and OS of hosted VMs are unknown. VMs with bridged networking inherit OT subnet membership.
Impact	If any VM is internet-connected or runs unpatched software, it provides a path from an untrusted environment to the OT subnet. Hypervisor vulnerabilities can also enable VM escape to the host, which has physical-layer OT access. Unknown VMs cannot be patched or monitored.
Recommendation	Document all VMs on this host. Determine whether any VM has internet connectivity and isolate it from OT. Consider whether VMware is appropriate on the OT subnet; if virtualisation is needed, use a hypervisor specifically evaluated for OT contexts.

Table 18: VMware host operating on the OT subnet with undocumented virtual machines

F-10 through F-15 - Medium / Low Findings

Table 19: Medium and Low Severity Findings

ID	Sev.	Recommendation Summary
F-10	MEDIUM	Determine if CPX-IOT has internet connectivity. If so, place behind a dedicated firewall with strict egress rules. Audit any cloud credentials stored on the device.
F-11	MEDIUM	Restrict PROFINET (Layer 2, EtherType 0x8892) to known switch ports via VLAN and port security. Disable DCP Set capability on production devices in TIA Portal if supported.
F-12	MEDIUM	Perform targeted protocol analysis (Modbus/502, IO-Link, REST) to characterise attack surface. Until confirmed, treat as unexposed and restrict to their station subnets.
F-13	MEDIUM	Access the UR Polyscope web interface to confirm firmware version. Apply latest UR firmware updates. Restrict UR Robot port 29999 (dashboard) and 30001-30004 (streaming) to authorised hosts only.
F-14	LOW	Add a secondary NTP source (hardware GPS clock or secondary server). Authenticate NTP with NTS or MD5 keys between the MES PC and PLCs.
F-15	LOW	Cross-reference MAC addresses with switch ARP tables and physically trace cables. Devices that cannot be identified should be removed from the network until documented.

2.4 Standards Alignment Summary

Table 20: Standards Compliance Summary

Standard / Requirement	Requirement Summary	Current Status	Findings
IEC 62443-1-1 Zone & Conduit	Define security zones; control conduits between zones	NOT MET - single flat zone	F-01, F-02, F-03
IEC 62443-2-1 CSMS	Asset inventory, risk assessment, access management, change control	PARTIAL - incomplete inventory, no documented procedures evident	F-04, F-09, F-15
IEC 62443-3-3 SR 5.1 / 5.2	Network segmentation; zone boundary protection	NOT MET	F-01, F-02, F-03
IEC 62443-3-3 SR 1.1 / 1.2	Human user identification; device authentication	NOT MET - no auth on S7comm, HTTP, or PROFINET	F-02, F-05, F-06, F-11
ISO/IEC 27001 A.8.1 Asset Mgmt	Complete, maintained asset register	PARTIAL - 6+ devices absent from inventory	F-04, F-09, F-15
ISO/IEC 27001 A.8.22 Segmentation	Separate groups of services and users	NOT MET	F-01
NIS2 Art. 21 Risk Management	Segmentation, access control, asset management	NOT MET in all three areas	F-01-F-09
NIS2 Art. 21(2)(e) Supply Chain	Manage vendor/software supply chain risk	NOT MET - unverified firmware across multiple vendors	F-10, F-13
Defense-in-Depth	Multiple independent security layers	NOT MET - single perimeter only	F-01-F-04
Least Privilege	Minimum necessary access per component	NOT MET - all devices have unrestricted subnet access	F-02, F-03, F-06
Zero Trust	No implicit trust from network location	NOT MET - trust granted by /18 membership	F-02, F-04, F-08

3 Threat Modelling

This analysis follows principles from IEC 62443, which defines a structured approach to identifying threats in Industrial Control Systems (ICS) based on zones, conduits, and system integrity requirements.

The assessment uses a simplified STRIDE model adapted for ICS environments and considers three attacker profiles: external attackers, insiders, and opportunistic student-level actors within a lab or training environment.

Industrial systems are particularly sensitive because compromise is not limited to data loss; manipulation can directly affect physical processes, safety constraints, and production continuity.

3.1 Attacker Profiles

External attacker

Typically motivated by financial gain (ransomware), disruption, or opportunistic exploitation of exposed services. Often relies on phishing, misconfigured remote access, or known vulnerabilities.

Insider

A user with legitimate access (operator, engineer, contractor). Capable of bypassing many perimeter controls and posing the highest risk for silent tampering.

Student / opportunistic actor

Low sophistication but high physical or local access in lab environments. Often responsible for accidental misconfigurations or simple exploitation of weak segmentation.

3.2 Threat Scenarios

PLC manipulation

An attacker gains access to the engineering environment or PLC network and modifies control logic (e.g., ladder logic, function blocks, or setpoints). This may result in unsafe actuator behaviour, incorrect process thresholds, or bypassed interlocks.

External attackers typically achieve this via compromised engineering workstations or remote access abuse. Insiders can perform direct modifications with minimal detection risk.

Denial of Service (DoS)

An attacker disrupts communication between PLCs, SCADA, and HMI systems by flooding network segments, exploiting protocol weaknesses, or overwhelming control servers.

Industrial protocols such as Modbus/TCP or OPC may lack robust authentication or rate limiting, making them vulnerable to traffic-based disruption.

Unauthorized device access

A rogue device is introduced into the control network, either physically or via network misconfiguration. Once connected, it can scan, impersonate trusted nodes, or interact with PLC services.

This scenario is particularly realistic in lab environments where physical access is possible.

Malware infection via Engineering PC

The Engineering Workstation is compromised via phishing, malicious downloads, or removable media. Once infected, attackers can pivot into PLC networks, extract logic files, or deploy malicious firmware changes.

This is one of the most critical ICS attack vectors because the Engineering PC often has unrestricted access to control assets.

Data manipulation via MES / Webshop systems

Attacks targeting Manufacturing Execution Systems (MES) or web interfaces allow modification of production orders, process parameters, or scheduling data.

This can lead to incorrect production batches, financial losses, or downstream process disruption in physical systems.

3.3 Threat Table

Asset	Threat	Attacker	STRIDE Category	Impact	Example Scenario
Engineering PC	Malware infection	External / Student	Information Disclosure, Tampering	Critical	Phishing leads to PLC compromise
Engineering PC	Unauthorized access	Insider	Elevation of Privilege	Critical	Engineer account reused or misused
PLCs	Logic manipulation	External / Insider	Tampering, Elevation of Privilege	High	Modified ladder logic alters actuator behaviour
PLCs	Command injection	Student / External	Spoofing	High	Fake control commands sent via Modbus
SCADA/HMI	Session hijacking	External	Spoofing	High	Attacker impersonates operator session
Network Segments	Traffic flooding	External	Denial of Service	High	Broadcast storm disrupts PLC communication
PLC Network	Configuration exfiltration	External	Information Disclosure	High	PLC logic downloaded and analysed
MES System	Production manipulation	External / Insider	Tampering	High	Batch parameters altered remotely
SCADA/HMI	Denial of service	External	Denial of Service	Medium-High	Flooding causes operator loss of visibility
Webshop/API	Data modification	External	Tampering, Information Disclosure	Medium-High	Order data changed, affecting production
Network Switches	Rogue device connection	Student / Insider	Spoofing	Medium	Unauthorized laptop joins control VLAN

Table 21: ICS Threat Analysis Matrix (IEC 62443-based)

4 Risk Matrix

Threat	Likelihood	Impact (Safety / Production / Education)	Risk Score	Priority
Engineering PC malware infection	High (3)	Critical (4): full compromise of control layer, persistent attacker access	12	Critical
PLC logic manipulation	Medium (2)	Critical (4): unsafe actuator behaviour, production shutdown, learning disruption	8	High
Unauthorized engineering access (insider misuse)	Medium (2)	Critical (4): silent logic changes, safety bypass possible	8	High
SCADA/HMI denial of service	Medium (2)	High (3): loss of operator visibility, production interruption	6	Medium
Network flooding / traffic storm	Medium (2)	High (3): loss of PLC communication, system downtime	6	Medium
MES production manipulation	Medium (2)	High (3): incorrect production runs, financial + operational impact	6	Medium
PLC configuration/data exfiltration	Medium (2)	High (3): loss of intellectual property + enables future attacks	6	Medium
Rogue device in network	Medium (2)	Medium (2): reconnaissance, lateral movement	4	Medium
Webshop/API data manipulation	Medium (2)	Medium (2): incorrect orders, indirect production issues	4	Medium
PLC command spoofing	Low (1)	High (3): incorrect control actions, potential physical instability	3	Low
Session hijacking (SCADA)	Low (1)	High (3): stealth control manipulation, loss of trust in system	3	Low

Table 22: ICS Threat Risk Assessment

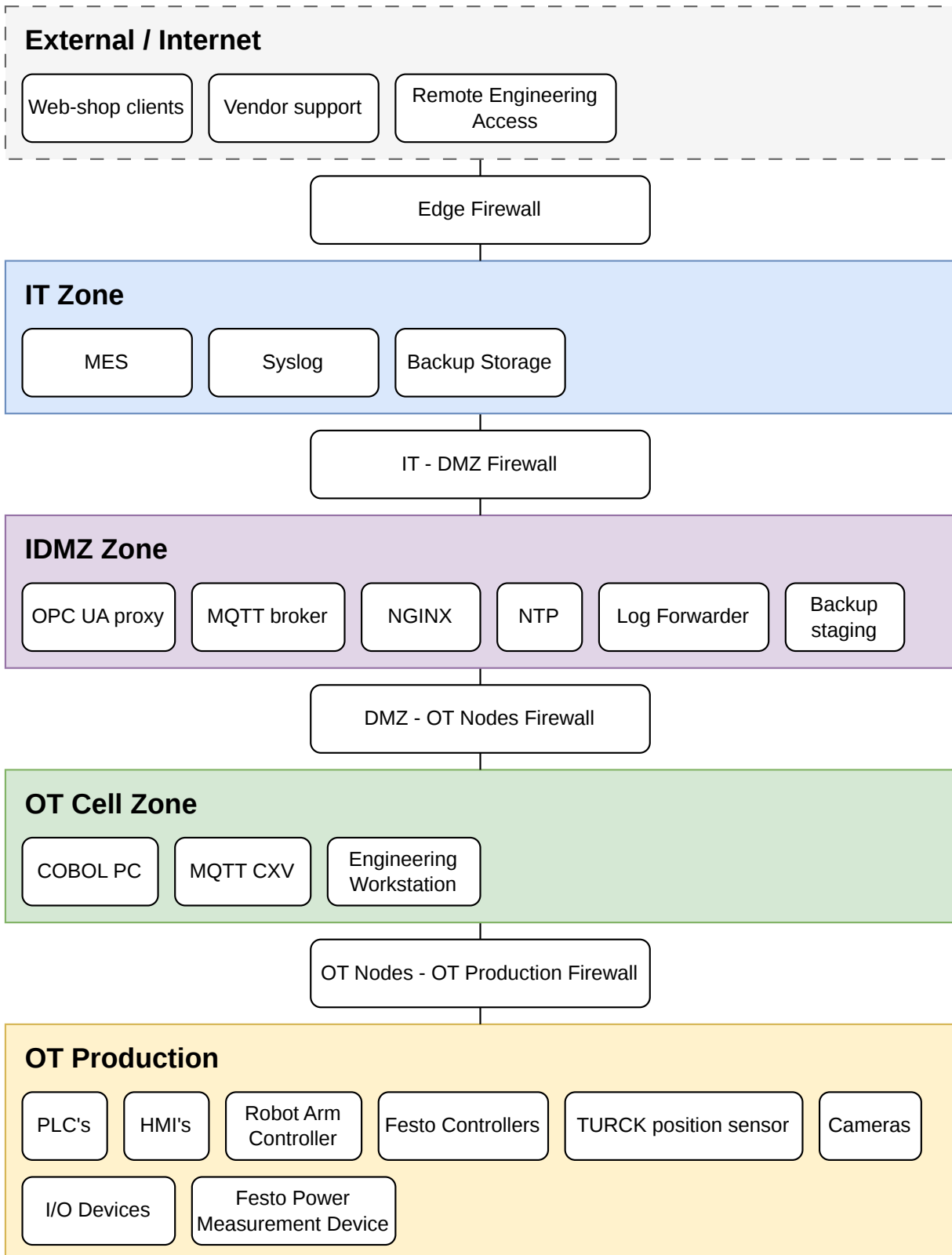
5 Security Requirements

SR-01	Network Segmentation
SR-01.1	The network shall be divided into the following security zones: - OT Field Zone (PLCs, HMIs) - OT Cell Zone (MQTT Device, Cobot / ML vision PC, Engineering Workstation) - Industrial DMZ (OPC UA Proxy, MQTT Broker, Backup Server, Historian) - IT Zone (MES Server, COBOL Vision System)
SR-01.2	Each zone shall be implemented as a separate subnet/VLAN. Communication between zones shall only be permitted through firewall-controlled conduits.
SR-01.3	Direct communication from the IT Zone to the OT Field Zone shall be prohibited.
Standards Reference	- IEC 62443-3-3 SR 5.1 – Restricted Data Flow - IEC 62443-1-1 – Zone and Conduit Model - NIS2 Article 21(2)(d)
SR-02	Firewall with protocol inspection
SR-02.1	The OT zones and IT zone shall be separated with the industrial firewall(s).
SR-02.2	Firewall rules shall enforce default-deny policy on all inter-zone traffic, with only explicitly whitelisted flows permitted: - OPC UA (TCP port 4840) from IDMZ OPC UA proxy to PLC's and Festo Controllers - MQTT (TCP port 8883 TLC) from MQTT device to MQTT broker in IDMZ
Standards Reference	- IEC 62443-3-3 SR 5.2 - IEC 62443-2-1 security management
SR-03	OPC UA Hardening
SR-03.1	All OPC UA servers shall operate in Security Mode: Sign&Encrypt with SecurityPolicy:Basic256Sha256.
SR-03.2	Each client (MES, COBOL) must authenticate with an application certificate. Anonymous and username/password authentication sessions shall be disabled.
SR-03.3	OPC/UA servers shall not be reachable from the nodes inside IT zone directly, all access routes shall be set through a dedicated OPC UA proxy in IDMZ
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 1.3, SR 3.1; OPC UA Part 2 (Security Model)

SR-04	MQTT Hardening
SR-04.1	The MQTT broker shall be hosted on a dedicated server inside IDMZ. All MQTT connections shall use TLS 1.2 or higher.
SR-04.2	Each MQTT publisher (MQTT CXV device) shall authenticate with a client certificate.
SR-04.3	Topic level ACLs must restrict publishers only to its own publish topics.
SR-04.4	Nodes in IT zone shall only subscribe (not publish) to the OT topics.
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)
SR-05	HTTP/Web Service Hardening
SR-04.1	All HTTP services on PLC's HMI's, Festo Controllers, and cameras shall be disabled unless strictly required for an operational functionality.
SR-04.2	If the Web Interface is required, it must be migrated to HTTPS (TLS 1.2+) with a device certificate, and access restricted by firewall to only specific source IP's of pooling systems.
SR-04.3	Topic level ACLs must restrict publishers only to its own publish topics.
SR-04.4	Nodes in IT zone shall only subscribe (not publish) to the OT topics.
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)
SR-06	Authentication and Least Privilege
SR-06.1	All interactive access (PLC programming, HMI configuration, robot controller configuration) to the OT devices shall require individual user authentication.
SR-06.2	Role separation shall be enforced: - Operator (monitor only) - Engineer (upload programs, change parameters) - Administrator (device configuration, user management)
SR-06.3	PLC Programming access (TIA Portal) shall be only possible from designated Engineering Workstation.
Standards Reference	- IEC 62443-3-3 SR 1.1–1.3; - IEC 62443-2-1 §4.3.3; - ISO/IEC 27001 A.9

<i>SR-07</i>	Secure Engineering Access
<i>SR-07.1</i>	A dedicated Engineering Workstation shall be physically or logically isolated from the IT Zone.
<i>SR-07.2</i>	The Engineering Workstation shall connect to PLC's only through industrial firewall via controlled conduit, with firewall rules permitting only TIA Portal protocols to the PLC's IP's.
<i>SR-08</i>	Logging and Monitoring
<i>SR-08.1</i>	All network devices (managed switches, routers, industrial firewalls, PLC's with switch modules) shall send logs to a centralized Syslog collector.
<i>SR-08.2</i>	The industrial firewalls shall log all denied traffic.
<i>SR-08.3</i>	OPC UA server shall log all sessions establishment and authentication failiures.
<i>SR-08.4</i>	The MQTT brocker shall log all connect/disconnect events and authentication failiures.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 6.1, SR 6.2; - NIS2 Article 21(2)(f); - ISO/IEC 27001 A.12.4
<i>SR-09</i>	NTP/Time synchronization
<i>SR-09.1</i>	A single NTP server must be designated. All OT devices shall synchronize using this server.
<i>Standards Reference</i>	- IEC 62443-2-1 §4.3.4; ISO/IEC 27001 A.12.3; NIS2 Article 21(2)(c)
<i>SR-10</i>	NTP/Time synchronization
<i>SR-10.1</i>	All PLC programs, HMI and Controllers configurations must be backed up after every change to and dedicated backup storage.
<i>SR-10.2</i>	Backup must be stored offline.
<i>SR-10.3</i>	Recovery procedure shall be documented and tested at least once per half a year.
<i>SR-10.4</i>	MES database shall be backed up once a day.
<i>Standards Reference</i>	- IEC 62443-2-1 §4.3.4; - ISO/IEC 27001 A.12.3; - NIS2 Article 21(2)(c)

6 Logical Network Redesign



The current flat /18 network is replaced with a layered zone architecture based on the IEC 62443 zone and conduit model. Each zone groups devices with similar operational functions. All inter-zone traffic passes through a firewall and is restricted to explicitly whitelisted traffic paths.

6.1 Logic Zones

IT Zone

The IT Zone contains nodes handling business logic and order management. It have no direct routed path to any OT device - all IT to OT traffic goes through the IDMZ.

IDMZ

The IDMZ acts as a buffer between IT and OT devices. No connection is allowed to pass from the IT to OT and vice versa. Every traffic exchange terminates inside IDMZ, and its re-initiated to the other side. This solution implements IEC 62443-3-3 SR 5.1 principle.

OT Cell Zone

The OT Cell Zone Contains devices supporting production, but not being part of the physical production process. The Engineering Workstation is placed in this logical zone, however, in physical implementation, this node will be further isolated into separate VLAN.

OT Production Zone

The OT Production Zone contains devices being part of the direct physical production process. Only inbound traffic allowed in this zone are reads and writes from the proxy services, and S7comm+ from the engineering workstation.

6.2 New Nodes

OPC UA proxy

In the AS-IS architecture, MES can directly connect to the PLC's OPC UA servers over the flat network. OPC UA proxy node aggregates all PLC's OPC UA servers traffic into single endpoint inside IDMZ. The MES connects only to proxy, that is also responsible for enforcing rules on what nodes are readable and writable from the MES. Furthermore, it logs all sessions. This solution satisfies IEC 62443-3-3 SR 3.2.

Nginx

In AS-IS architecture, MES can directly access unencrypted HTTP services from the OT nodes. As stated in security requirements, all not strictly required HTTP servers of OT devices will be disabled. However, for required HTTP traffic (e.g PLC's alarm table <- MES) the Nginx node is introduced in IDMZ. MES connects to the Nginx over HTTPS TLS 1.2, terminates the connection, access the requested HTTP node server and forwards it to the MES. Nginx enforces authentication, logging all requests and block requests for services that should not be reached from IT zone.

Dedicated MQTT broker

In the AS-IS architecture MQTT CVX device publish messages over a flat network to the MES. MQTT broker node placed in IDMZ, aggregates MQTT traffic from the CVX device using TLS 1.2 encryption, and it restrict inbound traffic to publish messages only. MES is subscribes to the MQTT broker, preventing direct communication between OT node and IT node. This solution satisfies IEC 62443-3-3 SR 1.1 and SR 3.1.

Engineering Workstation

In the AS-IS architecture, TIA Portal is run on the same PC as MES service - part of IT and reachable over flat network. A dedicated Engineering Workstation is placed in the OT Cell Zone (physically on separate VLAN). This workstation purpose is to program and configure PLC's and HMI's with separation from IT nodes. Traffic is restricted only to TCP 102 on PLC's and HMI's. This enforces least-privilege and IEC 62443-2-1 §4.3.3.

Syslog

In the AS-IS architecture, there is no centralized logging system implemented. Syslog node collects all logs from the firewalls, managed switches, OPC UA and HTTP proxy, and MQTT broker. This provides post-attack analysis and satisfies IEC 62443-3-3 SR 6.1 and NIS2 Article 21(2)(f).

Backup

In AS-IS architecture, there is no documented backup procedure. The backup node receives configuration backups from the Engineering Workstation after every change and daily database backups from the MES. It is placed on separate VLAN inside IT zone, separated from inbound traffic from OT. Satisfies IEC 62443-2-1 §4.3.4 and ISO/IEC 27001 A.12.3.

Log & Backup proxy

6.3 Firewalls

This section only describes briefly the high-level purpose of the firewall nodes. Further specification on permitted conduits is described in 7.2.2.

Edge Firewall

Terminates all VPN tunnels from remote engineers and vendor support, enforces MFA before any traffic enters the IT zone, and blocks all unsolicited inbound connections from the internet. Default-deny on all inbound. Satisfies IEC 62443-2-1 §4.3.3.6 and NIS2 Article 21(2)(i).

IT - DMZ Firewall

Controls all traffic between the IT zone and the DMZ.

DMZ - OT Cell Firewall

Controls traffic between the DMZ and the OT cell zone.

OT Cell - OT Production Firewall

Controls traffic between the OT cell zone and the six station VLANs. OPC UA proxy connections arrive from the DMZ side, not the cell zone side, so they do not pass this firewall. Profinet never crosses this boundary — it remains Layer 2 within each station. All other traffic denied. Satisfies IEC 62443-3-3 SR 5.1 and the least privilege principle.

6.4 Network Implementation

The Network Implementation diagram is appended to the report for better visibility.

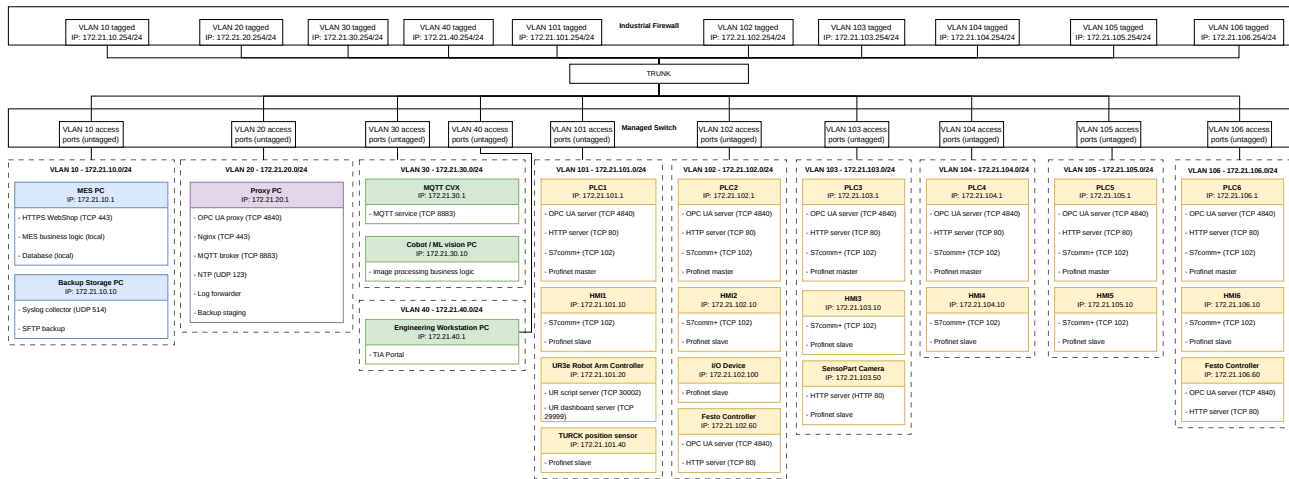


Figure 2: Network Implementation

6.5 VLAN Segmentation & Restricted Routing

The redesigned factory network is implemented using VLAN-based segmentation on managed industrial switches. Each security zone is assigned a dedicated VLAN and IP subnet. Inter-VLAN communication is not performed by the switch itself but is routed through a central industrial firewall. The firewall has one tagged VLAN port for each VLAN - which is a default gateway for each node withing that VLAN. The firewall enforces security policies between zones. A VLAN trunk connection between the firewall and the managed switch transports traffic for all security zones while preserving logical separation through IEEE 802.1Q VLAN tagging.

Because the switch never bridges VLANs, the only path between any two zones is through the firewall. The firewall applies a default-deny policy: traffic between VLANs is dropped unless a rule explicitly permits it. Traffic within a VLAN (for example PLC-to-HMI Profinet inside one station) is switched locally and never reaches the firewall. Profinet RT traffic is Layer 2 only and is confined to its station VLAN; it is never routed across the firewall. This realises the four logical firewall boundaries (Edge, IT-IDMZ, IDMZ-OT Cell, OT Cell-OT Production) on a single physical firewall, where each boundary corresponds to a rule set between the relevant VLAN interfaces. It satisfies IEC 62443-3-3 SR 5.1 (Restricted Data Flow) and SR 5.2 (Zone Boundary Protection).

VLAN	Zone	Nodes
10	IT	MES PC, Data Storage PC
20	IDMZ	Proxy PC
30	OT Cell	COBOL PC, MQTT CVX
40	OT Cell - Engineering	Engineering Workstation
101	OT Prod - Station 1	PLC1, HMI1, UR3e Robot Arm Controller, TURCK position sensor
102	OT Prod - Station 2	PLC2, HMI2, I/O device, Festo Controller
103	OT Prod - Station 3	PLC3, HMI3, SensoPart Camera
104	OT Prod - Station 4	PLC4, HMI4
105	OT Prod - Station 5	PLC5, HMI5
106	OT Prod - Station 6	PLC6, HMI6, Festo controller

6.6 Justified Protocols Routes

The permitted flows exist to allow a required operational functionality - all other are denied. The IT node never reaches an OT node directly. All IT to OT connections are terminated and re-initiated in the IDMZ proxy to the other side.

Flow	Path	Protocol/Port	Justification
Process Data, MES to PLC	MES to OPC UA proxy to PLC's OPC UA server	OPC UA/TCP4840	MES reads/writes process data. MES connection is terminated in OPCUA proxy. No direct connection between MES and PLC.
Web data, MES to OT nodes	MES to Nginx to OT nodes web server	HTTPS/TCP443 (IT side), HTTP/TCP80 (OT side)	Required Web data from OT nodes is fetched by Nginx reverse proxy instead of MES directly - plain text HTTP stays in OT zone, and Nginx connects to MES through HTTPS.
Telemetry, MQTT CVX device to MES	MQTT CVX to MQTT broker to MES (subscribe)	MQTT/TCP8883 TLS	OT only publish, IT only subscribe
PLC/HMI programming	Engineering Workstation to HMI's/PLC's	S7comm+/TCP102	Programming only from the dedicated workstation in the engineering VLAN
Cobot process data	Cobot/MLvisionPC to PLC2	OPC UA/TCP4840	Vision PC needs PLC2 data only; scoped to Station 2
Time synchronization	All devices to NTP server	NTP/UDP123	Single time source for all OT devices
Logging	All devices to Syslog collector	Syslog/UDP514	Centralised log collection for monitoring
Webshop	Internet clients to MES	HTTPS/TCP443	Public webshop terminates in IT, no OT reachability

7 Protocol Hardening

The redesign (Chapter 7) controls where each protocol may flow. This chapter defines how each protocol is secured on the device and conduit level.

7.1 Profinet

Profinet has no authentication or encryption features, so it cannot be hardened at the protocol level. Instead it is secured by isolation.

- Layer 2 only - Profinet stays inside each OT Production station (VLAN 101 - 106). It is never routed, and never crosses through firewall. Even if routing would be executed (through the attack) router would drop the communication.
- No inter-station Profinet communication - Each PLC talks Profinet (with I/O, HMI) only within own VLAN.
- DCP Set disabled - disable DCP Set through TIA Portal for devices that support this feature. This prevents rename/reconfigure attacks through DCP.

7.2 OPC UA

OPC UA is the only routed OT data protocol. Hardening is specified in SR-03. (*see Security Requirements 6.1 TODO*)

- Security mode Sign&Encrypt - Security policy Basic256Sha256. Mode 'none' is disabled on all PLC and Festo Controllers servers.
- Certificate authentication - Clients (OPC UA proxy, Cobot/MLvisionPC) authenticate with application certificates. Anonymous and username/password sessions are disabled.
- Scoped access - The Cobot/MLvisionPC can reach only PLC2 on Station 2, and no other PLC's.

7.3 MQTT

MQTT is used by the Festo CXV device for telemetry. It's hardening is specified in SR-04 (*see Security Requirements 6.1 TODO*)

- MQTT broker in IDMZ - The MQTT CXV device publishes only to a dedicated MQTT broker placed in IDMZ. IT nodes can only subscribe to the broker. No direct OT-IT MQTT path exists.
- TLS 1.2+ - TLS encryption enforced on all MQTT connections.
- Client certificates - MQTT CXV device must authenticate with certificate for publish connection to the broker. No anonymous connections allowed.
- Topic ACL's - The MQTT CXV device may publish only to it's own topics. IT nodes (MES) cannot publish to the OT topics.

7.4 HTTP/Web Interfaces

Some OT devices need to expose plaintext HTTP web interfaces. Hardening is specified in SR-05 (*see Security Requirements 6.1 TODO*)

- Disabled by default - All HTTP servers are disabled unless strictly needed for operational functionality.

- Reverse proxy - Where web access is needed (e.g. MES reading the PLC alarm table), the MES connects to the Nginx reverse proxy in the IDMZ over HTTPS/TLS 1.2+. Nginx terminates the connection, fetches the OT-side resource, and returns it. Plaintext HTTP stays inside the OT zone.
- Access restriction - Nginx authenticates requests, logs them and blocks any OT server that should not be reached from IT zone. Firewall rules restrict web access to the Nginx TCP/IP port only.

7.5 S7comm+ Engineering Access

S7comm+ connection is used only for programming PLC's and HMI's. Hardening is specified in SR-06 and SR-07
 TODO link to SR's

- Single source - S7comm+/TCP102 to any PLC or HMI is allowed only from the dedicated Engineering Workstation in VLAN40.
- Conduit control - Engineering Workstation S7comm+ connection initialization passes through the firewall, enforcing restriction of Engineering Station to PLC's and HMI's only.
- User Authentication - PLC's and HMI's access requires individual login/password authentication with role separation (implemented in TIA portal).

8 Security Hardware

This chapter lists the hardware required to implement the redesigned architecture (Chapter 7).

8.1 Industrial Firewall

Model	Fortinet FortiGate Rugged 70G
Function	Central Layer 3 firewall and inter-VLAN router. All traffic between VLANs passes through it - under default-deny polict. Can perform stateful filtering and packet inspection of industrial protocols (S7comm+, OPC UA, MQTT, HTTP/S). Implements four logical firewalls (Edge, IT-IDMZ, IDMZ-OT Cell, OT Cell-OT Production) as separate rule sets between VLAN interfaces.
Placement	Network core. Has one tagged VLAN interface (.254 gateway) per VLAN. Has single 802.1Q trunk to the managed switch. No VLAN is bridged on the switch, so the firewall is the only inter-VLAN path.

8.2 Managed Switch

Model	Siemens SCALANCE XC-216
Function	VLAN-aware Layer 2 switching with IEEE 802.1Q tagging. Provides per-station access ports (untagged, one VLAN each) and the trunk uplink to the firewall.
Placement	Replace the existing unmanaged SCALANCE XB008 switches at each station. Interconnected by 802.1Q trunks; one trunk reaches the firewall.

8.3 Engineering Station

Model	Siemens SIMATIC IPC627E
Function	Dedicated managed station running TIA Portal for PLC and HMI programming/configuration. Only host permitted S7comm+ to PLCs/HMIs.
Placement	OT Cell zone, isolated in its own VLAN (40). Reaches OT Production only through the firewall on TCP 102.

8.4 IDMZ proxy server

Model	Industrial rack server or SIMATIC IPC. Hardened Linux.
Function	Hosts the IDMZ services — OPC UA proxy, Nginx reverse proxy, MQTT broker, NTP master, log forwarder, backup staging.
Placement	Placed inside IDMZ zone - on VLAN20.

8.5 Syslog & Backup Storage

Model	Standard server, Linux OS.
Function	Central Syslog collector for firewall, switches, proxies and broker; offline configuration backups (after every change) and daily MES database backups over SFTP.
Placement	IT zone, VLAN10

9 Organizational & Procedural Measures

9.1 User Roles

Three roles, enforced on PLCs, HMIs, controllers, and the robot (SR-06.2). All access uses individual accounts — no shared logins.

Role	Permissions	Typical User
Operator	Monitor HMIs, access Web Interfaces. No configuration or program changes.	Student running a session
Engineer	Upload/modify PLC programs and parameters, configure HMIs. Login through Engineering Workstation only.	Lab technician / Teacher
Administrator	Device configuration, user and certificate management, firewall and switch configuration.	Lab administrator

9.2 Backup Strategy

Backup Strategy is specified in SR-10 (see TODO).

- PLC programs, HMI configurations, and controller configs are backed up after every change.
- The MES database is backed up daily.
- Backups go to dedicated backup storage (VLAN 10) and a copy is kept offline.
- Recovery procedures are documented and tested at least twice per year.

9.3 Incident Response

- Detect — Anomalies surface from the Syslog collector and firewall denied-traffic logs (SR-08). Operators report unexpected station behaviour immediately.
- Contain — Isolate the affected device or VLAN (disconnect or firewall block). Stop the station if process safety is in doubt.
- Preserve — Keep logs and alarms.
- Recover — Restore PLC/HMI config or MES data from the last known-good backup (SR-10.4).
- Document — Record what happened, the cause, and the fix.